信息安全测评与风险评估

4.3 数据库安全配置核查

授课教师：张玉



目录

CONTENTS

01 案例导入：数据库被拖库，日志里却什么都没有

02 关键知识：7 个维度与核查命令

03 动手实验：西普真机取证 + 判定

04 课内小结与下节预告

Part.01

案例导入——
数据库被拖库，日志里却什么都没有



案例导入——“沉默的数据库”

Q:数据库被拖库了，但日志里什么都没有——问题出在哪?

某电商平台数据泄露事后调查：

- 密码策略未配置，DBA弱口令
- 审计日志未启用，无法追溯
- SA账户未禁用，允许远程登录
- 未做网络隔离（0.0.0.0:3306）
- 数据明文存储，备份未加密

先想一想（30 秒）

- 1. 上面 5 个问题，分别对应等保里的哪个测评维度？
- 2. 为什么"日志里什么都没有"比数据泄露本身更严重？
- 3. 换你来查这个库，第一条命令你会敲什么？



数据库是信息系统的“心脏”，数据泄露往往从安全配置的“漏洞”开始。

学习目标

学完这一节，你应该能做到：

1. 说清数据库在等保里的 7 个测评维度各自查什么
2. 在 MySQL 和 SQL Server 上用命令查出账号、口令、权限、审计的真实配置
3. 认出弱口令、空口令、SA 未禁用、无审计、0.0.0.0 监听这些典型隐患
4. 录入实测值、做四档判定，导出规范的测评记录表
5. 针对不合规项，写出可直接执行的 SQL 或配置修改建议

Part.02

关键知识——7 个维度怎么查



数据库安全测评——在等保标准中的位置

GB/T 22239-2019 安全技术要求 → 安全计算环境 → 数据库层

安全计算环境涉及数据库的测评指标（共7个维度）：

维度	测评内容核心关注点	测评方法（检查项）
1.身份鉴别	密码策略、登录失败处理、远程管理安全	登录数据库查看配置
2.访问控制	账户权限、默认账户、最小权限原则	查看用户/权限配置
3.安全审计	审计功能是否启用、审计内容是否完整	查看审计配置与日志
4.入侵防范	最小安装、关闭高危端口/服务	查看服务/端口配置
5.数据完整性	传输/存储过程中的完整性保护	查看加密/校验配置
6.数据保密性	传输/存储过程中的加密保护	查看加密配置
7.数据备份恢复	备份策略、恢复机制	查看备份配置

1.身份鉴别测评——数据库的第一道防线

GB/T 22239 第三级 安全计算环境
→ 身份鉴别

核心检查项（针对数据库）		
序号	检查项与要求	常见不合规示例
1	**身份标识与鉴别：**用户登录需鉴别，标识应唯一	存在空口令账户
2	**密码复杂度：**配置策略（≥8位，含大小写+数字+特殊字符）	未装validate_password插件
3	**密码定期更换：**密码应定期更换（建议90天）	default_password_lifetime=0
4	**登录失败处理：**启用失败处理（限制非法登录次数）	无账户锁定策略
5	**远程管理安全：**远程管理应采取加密措施（SSL/TLS）	未启用SSL加密

MySQL 操作示例

```
-- 检查/安装密码策略插件SHOW PLUGINS LIKE'validate_password';INSTALL
COMPONENT 'file://component_validate_password';
-- 策略级别: MEDIUM, 最小长度: 12 SET GLOBALvalidate_password.policy =
MEDIUM;SET GLOBALvalidate_password.length = 12;
-- 设置密码90天过期SET GLOBALdefault_password_lifetime = 90;
```

SQL Server 操作示例

```
-- 检查审核级别(应为'all')EXECxp_loginconfig 'audit level';
-- 禁用SA账户ALTER LOGINsaDISABLE;
-- 检查空口令账户
SELECTnameFROMsys.sql_loginsWHEREpassword_hashIS NULL;
```

1.身份鉴别测评——常见问题与整改

常见不合规问题	风险描述	整改建议
未安装密码复杂度插件	用户可设置弱口令，易被暴力破解	安装validate_password插件，启用MEDIUM策略
密码永不过期	长期使用同一密码，泄露风险高	设置default_password_lifetime=90
SA账户未禁用	SA拥有最高权限，被攻击后系统完全沦陷	禁用SA账户，创建专用服务账户
存在空口令账户	任何人都可以无密码登录	检查并删除空口令账户
远程管理未加密	密码在网络中明文传输，可被嗅探	启用SSL/TLS加密连接
无登录失败限制	可无限次尝试密码，易被暴力破解	配置登录失败锁定策略

2.访问控制测评——谁有权，访问什么

GB/T 22239 第三级 安全计算环境 → 访问控制

核心检查项（针对数据库）：

检查项	合规要求	不合规示例
账户分配	应对登录的用户分配账户和权限	多个运维人员共用一个账户
默认账户	应重命名或删除默认账户，修改默认口令	SA账户未禁用

MySQL操作示例

MySQL

```
-- 检查root账户是否只允许本地登录
SELECT user, host FROM mysql.user WHERE user='root';

-- 删除匿名用户
DELETE FROM mysql.user WHERE User='';
-- 创建专用应用账户（最小权限）
```

SQL Server操作示例

SQL Server

```
-- 检查SA账户状态
SELECT name, is_disabled FROM sys.server_principals;

-- 禁用SA账户
ALTER LOGIN sa DISABLE;
-- 创建角色并分配最小权限
```

3.安全审计测评——出了事有据可查

GB/T 22239 第三级 安全计算环境 → 安全审计

核心检查项（针对数据库）

检查项	要求说明	不合规示例
审计功能启用	应启用安全审计功能，审计覆盖到每个用户	审计功能未启用
审计内容完整	审计记录应包括日期、时间、用户、事件类型、结果等	审计记录不完整
审计记录保护	应对审计记录进行保护，定期备份，防止删除/修改/覆盖	审计日志可被普通用户删除
审计进程保护	应对审计进程进行保护，防止未经授权的中断	审计进程可被随意停止

MySQL操作示例

```
-- 检查审计插件是否安装（MySQL Enterprise版）SHOW PLUGINS LIKE 'audit_log';
-- 社区版可使用MariaDB audit_log插件INSTALL PLUGIN audit_log SONAME 'audit_log.so';
-- 启用全量审计SET GLOBAL audit_log_policy = 'ALL';
-- 性能敏感场景：仅审计关键操作SET GLOBAL audit_log_policy =
'LOGINS,QUERIES_DDL,QUERIES_DCL';
-- 检查通用日志状态（排障时临时开启）SHOW VARIABLES LIKE 'general_log%';
```

SQL Server操作示例

```
-- 启用服务器审计USE master;CREATE SERVER AUDIT ServerAuditTO FILE
(FILEPATH = 'C:\Audits\')WITH (QUEUE_DELAY = 1000, ON_FAILURE =
CONTINUE);ALTER SERVER AUDIT ServerAudit WITH (STATE = ON);
-- 创建审计规范（记录登录事件）CREATE SERVER AUDIT SPECIFICATION
LoginAuditSpecFOR SERVER AUDIT ServerAuditADD
(FAILED_LOGIN_GROUP),ADD (LOGIN_CHANGE_PASSWORD_GROUP);ALTER
SERVER AUDIT SPECIFICATION LoginAuditSpec WITH (STATE = ON);
```

4.入侵防范测评——减少攻击面

GB/T 22239 第三级 安全计算环境 → 入侵防范

核心检查项（针对数据库）

检查项	要求说明	不合规示例
1. 最小安装	仅安装需要的组件和应用程序	安装了不必要的组件
2. 关闭高危服务	应关闭不需要的系统服务、默认共享和高危端口	数据库监听在默认端口1433/3306
3. 管理终端限制	应通过设定终端接入方式或网络地址范围进行限制	允许任意IP访问数据库

- **MySQL操作示例**

```
-- 检查bind-address配置（不应监听所有网卡）
SHOWVARIABLESLIKE'bind_address';
-- 生产环境应设置为具体内网IP，而非0.0.0.0

-- 检查是否修改了默认端口
```

- **SQL Server操作示例**

```
-- 检查是否修改了默认端口（1433）
-- 需通过SQL Server配置管理器查看

-- 禁用高危扩展存储过程
EXECsp_configure'show advanced options',1;
```

5.数据完整性与保密性测评

GB/T 22239 第三级 安全计算环境 → 数据完整性、数据保密性

核心检查项

检查项	阶段	合规标准
数据完整性	传输	启用SSL/TLS加密传输
数据完整性	存储	启用TDE或数据校验
数据保密性	传输	启用SSL/TLS加密传输
数据保密性	存储	启用TDE或列级加密

MySQL 操作示例

```
-- 检查SSL是否启用 SHOW VARIABLES LIKE 'have_ssl';
 -- 检查是否强制使用SSL SHOW VARIABLES LIKE
'require_secure_transport';
-- 检查未要求SSL的用户 SELECT user, host, ssl_type FROM
mysql.user WHERE ssl_type = '';
```

SQL Server 操作示例

```
-- 检查TDE是否启用 SELECT name, is_encrypted FROM
sys.databases;
-- 检查连接加密状态 SELECT session_id, encrypt_option FROM
sys.dm_exec_connections;
```

6.数据备份恢复测评

GB/T 22239 第三级 安全计算环境 → 数据备份恢复

核心检查项

检查项	要求	不合规示例
本地备份	应提供重要数据的本地数据备份与恢复功能	不合规: 未配置任何备份策略
异地备份	应提供异地实时备份功能（第三级）	不合规: 备份仅保存在本地
高可用	应提供重要数据处理系统的热冗余	不合规: 数据库单机运行，无高可用

检查要点

- ? 是否有定期备份计划（每日/每周）？
- ? 备份是否存储在异地？
- ? 是否定期进行恢复演练？
- ? 是否配置了主从复制或集群？

从知识到实验：查一份库按这个顺序走

1

1 看环境

数据库版本、实例名、监听端口，先看清楚再动手

系统信息查询

2

2 查身份鉴别

口令策略、空口令账户、SA/root 是否禁用

数据库客户端

3

3 查权限与网络

账户权限、bind-address、SSL 是否加密

SQL查询语句

4

4 查审计与备份

审计日志是否启用、备份与异地备份策略

日志查看工具

5

5 记录并判定

逐条录入（可用 JSecProbe） + 四档判定

测评记录表

Part.03

动手实验

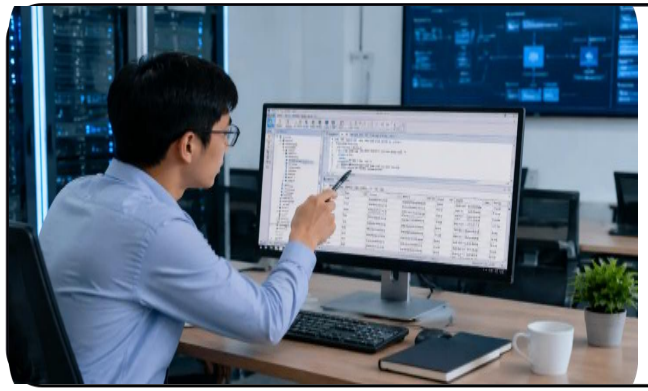
——

西普真机取证 + 判定



本讲实验总览

素材4：教师演示
用——数据库核查



① 取证：西普实验平台

登录 10.11.0.70（账号=学号，密码=学号+1q2w），按照

② 上机五步：选 → 查 → 录 → 判 → 交

① **选：MySQL 线与 SQL Server 线各选 1~2 个实验**
先看清库的版本、实例名和端口，再动手

② **查：在真实库上跑核查命令，逐条截图留证**
回显里要能看到命令本身和真实返回值

③ **录：把回显里的真实值抄进 JSecProbe「现场核查」或AI工具**
抄参数值，不抄结论，如 `default_password_lifetime=0`

④ **判：对照基线做四档判定，写清"做到哪、差在哪"**
一条判定配一张回显截图，编号与记录表对应

⑤ **交：导出《数据库安全测评记录表》，课内提交**
交不了就先交已完成部分并注明，不要填假数据

! **两条纪律**
只在平台实验库上操作，不做删库、改密等破坏性动作；
截图只交作业不外传

步骤①：选什么——西普平台实验清单（MySQL 线 + SQL Server 线）

编号	西普平台实验 / 你要查什么	覆盖维度
M1	MySQL 安全配置核查 → 口令策略与账户：validate_password 插件、密码有效期、空口令与匿名账户	8.1.4.1 / 8.1.4.2
M2	MySQL 安全配置核查 → 权限与网络：root 是否允许远程、用户权限、bind-address、端口、SSL	8.1.4.2 / 8.1.4.4 / 8.1.4.7
M3	MySQL 安全配置核查 → 审计与日志：审计插件状态、general_log、日志留存与保护	8.1.4.3
S1	SQL Server 安全配置核查 → 登录与账户：审核级别、SA 账户状态、空口令账户	8.1.4.1 / 8.1.4.2
S2	SQL Server 安全配置核查 → 审计与权限：服务器审计是否启用、登录审计规范、危险存储过程	8.1.4.3 / 8.1.4.4
S3	SQL Server 安全配置核查 → 加密与备份：TDE 加密状态、连接加密、备份与异地备份	8.1.4.7 / 8.1.4.8 / 8.1.4.9
推荐	M1 + M3（或 S1 + S2）：口令与审计是数据库测评最高频的丢分点，两条线合起来覆盖 ≥4 个维度	课内完成

Part.04

回顾与拓展
课内小结与下节预告



职业提醒——你查的每一行配置，背后都是人的信息



守护

数据库存储的是客户信息、交易记录、医疗档案……一次配置失误，可能影响成千上万的人



合规

《网络安全法》《数据安全法》《个人信息保护法》对数据安全有明确要求，测评工程师的每一次核查，都是在推动法律落实



担当

“数据库安全无小事”，发现一个配置漏洞，可能避免一次大规模数据泄露

一句话：你填的每一个"不符合"，都可能挡住一次真实的数据泄露。

知识点回顾

数据库安全配置核查

1 身份鉴别

密码复杂度、定期更换、登录失败处理、远程加密

2 访问控制

最小权限、禁用SA/root远程、权限分离

3 安全审计

功能启用、内容完整、记录保护

4 入侵防范

最小安装、修改默认端口、禁用高危功能

5 完整性/保密性

传输加密（SSL/TLS）、存储加密（TDE）

6 数据备份恢复

本地备份、异地备份（三级）

下节课预告

任务4.4：应用系统安全功能验证

预告内容

- 身份鉴别功能验证
- 访问控制功能验证
- 安全审计功能验证

课前准备

- 复习GB/T 22239中“安全计算环境-应用系统”相关要求
- 准备Web应用测试环境

感谢观看

